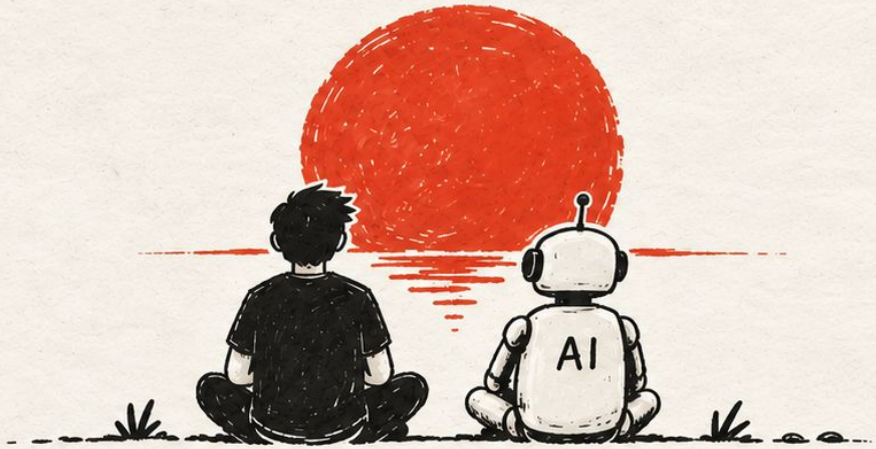
THE CHAOS PHASE

Or: How I Learned to Stop Worrying and Love Offensive AI



OFF BY ONE / SINGAPORE

NICO WAISMAN / XBOW

Off by one - Mandatory story

A 3 a.m. Riddle

From: Nicolas Waisman <nicolas.waisman () immunitysec com>
Date: Wed, 30 May 2007 01:13:10 -0500

```
Lets have a fun riddle to cheer up the spirit ( Mate at 11pm, its all
night insomnia.)

 The riddle: Let said you are trying to exploit a remote service on an
old Windows 2000 (whatever SP you want) and the primitive is the following
    inc [edi]   // you control edi

 What would be the best option for edi?


Nico

_______________________________________________
Dailydave mailing list
Dailydave () lists immunitysec com
http://lists.immunitysec.com/mailman/listinfo/dailydave
```

Security is an **economic** problem

2001.

Windows 2000. IIS 5.0.
A reachable buffer overflow.
Code execution as Local System.

FROM: BILL GATES / SUBJECT: TRUSTWORTHY COMPUTING

From: Bill Gates
Sent: Tuesday, January 15, 2002 5:22 PM
To: Microsoft and Subsidiaries: All FTE
Subject: **Trustworthy computing**

Every few years I have sent out a memo talking about the highest priority for Microsoft. Two years ago, it was the kickoff of our .NET strategy. Before that, it was several memos about the importance of the Internet to our future and the ways we could make the Internet truly useful for people. Over the last year it has become clear that ensuring .NET is a platform for Trustworthy Computing is more important than any other part of our work. If we don't do this, people simply won't be willing -- or able -- to take advantage of all the other great work we do. Trustworthy Computing is the highest priority for all the work we are doing. We must lead the industry to a whole new level of Trustworthiness in computing.

Fix the bug.
Change the economics.

Stack protection. DEP. ASLR.
Control-flow defenses. Sandboxes.

DAYS → WEEKS → MONTHS



DAYS

Find a bug.
Build a PoC.
Get code execution.

WEEKS

Make it reliable.
Handle different versions.
Bypass mitigations.

MONTHS

Deep expertise.
Complex chains.
More expensive to burn.

THE GOOD PART

Security industrialized.

SDL. CVEs. Bug bounties.
Assurance. Shared standards.

We optimized the proxy.

Tickets closed != attack paths closed.

CONTEXT IS PART OF THE FINDING

Potential != risk.

Present != reachable.
Reachable != exploitable.
Severity != business impact.

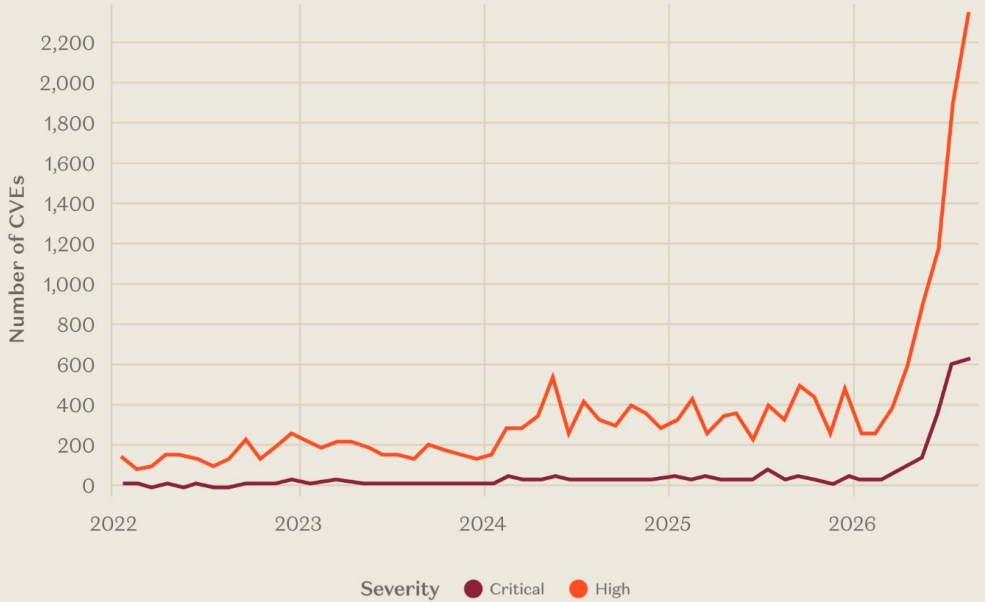
POC || GTFO

History repeats.
This time, with an API.

The tools changed.
The economic problem did not.

Cyber Risk Goes Parabolic

Critical and high severity vulnerabilities



Source: Epoch.ai. CVEs from Adobe, AMD, Apache, Apple, AWS, Cisco, GitHub, Google, IBM, Intel, Linux, Microsoft, Mozilla, NVIDIA, OpenSSL, Oracle, Qualcomm, Red Hat, Samsung, SAP, and VMware. Reporting procedures, labeling, and cadence vary substantially between organizations. (9/3/26)

Zerodayclock



What attackers were scanning this week

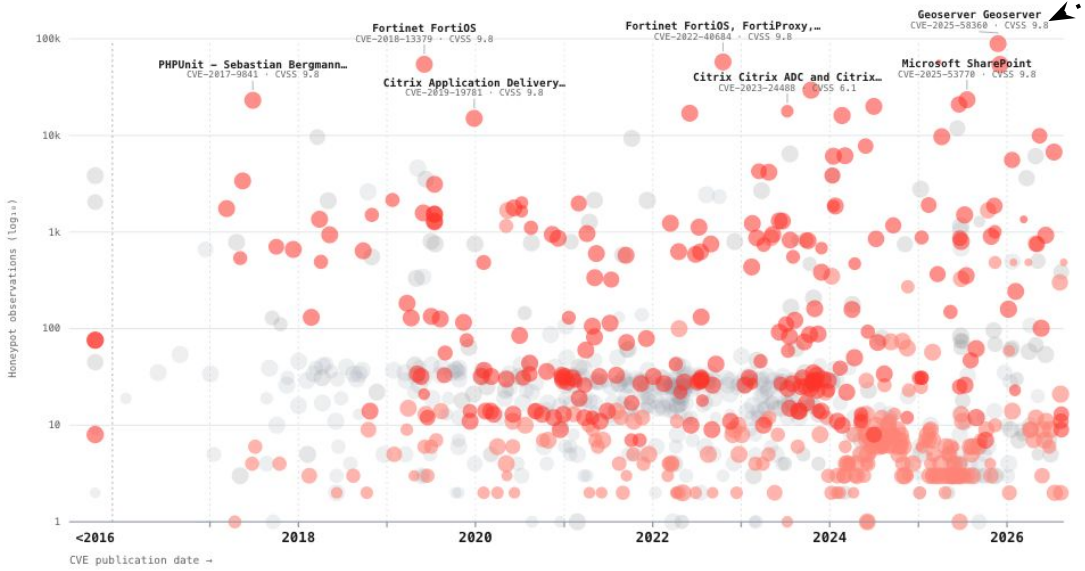
2026-08-30 → 09-05 ← → Screenshot ⤢ Enlarge

Every bubble is one vulnerability that honeypot sensors saw someone try over the last 7 days, placed left to right by the year its CVE was published and stacked by how much traffic it drew.

OBSERVED TO 2026-09-05

7 DAY WINDOW most recent complete week

● rose against the window before ● fell ● indistinguishable from noise ● not observed in the window before ◉ outer ring = ransomware-associated



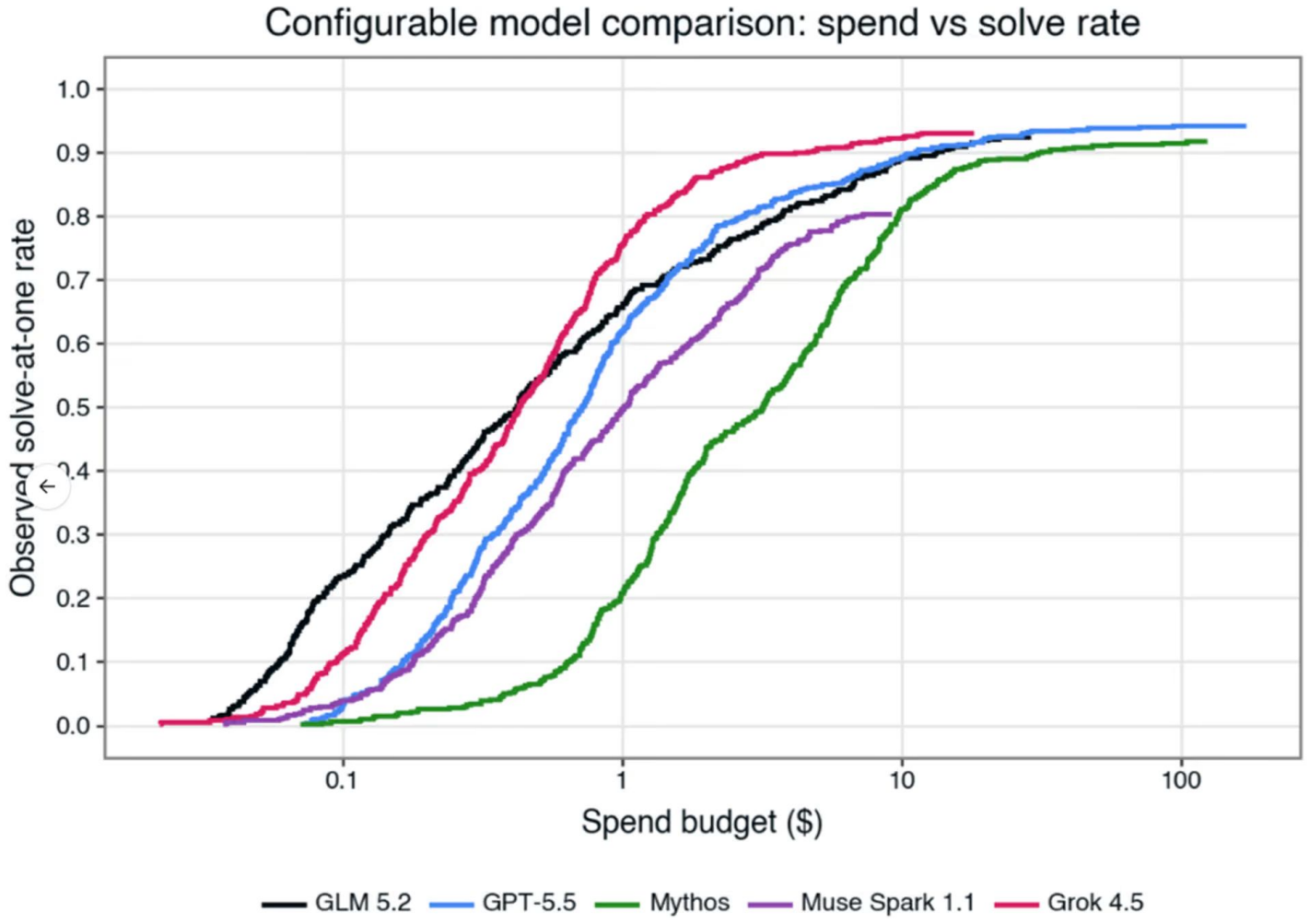
Source: Shadowserver ● ZERODAYCLOCK.COM

How to read it. One mark per vulnerability the honeypots saw this week, placed at its publication date. Height is observations on a log scale, so each gridline is ten

AI attacks at the cost of iteration.

Explore. Test. Learn. Repeat.


Solver Agent Performance Across Experiments
Solver Success Rate
100%
80%
60%
40%
20%
Sonnet 3.7
Gemini 2.5
Alloy 3.7/2.5
Sonnet 4.0
Alloy 4.0/2.5
Opus-4.1
GPT-5
Gemini-3
Opus-4.5
GPT-5.2
Opus-4.6
Alloy 4.6/3.1


Configurable model comparison: spend vs solve rate
Observed solve-at-one rate
1.0
0.9
0.8
0.7
0.6
0.5
0.4
0.3
0.2
0.1
0.0
0.1
1
10
100
Spend budget ($)
GLM 5.2
GPT-5.5
Mythos
Muse Spark 1.1
Grok 4.5

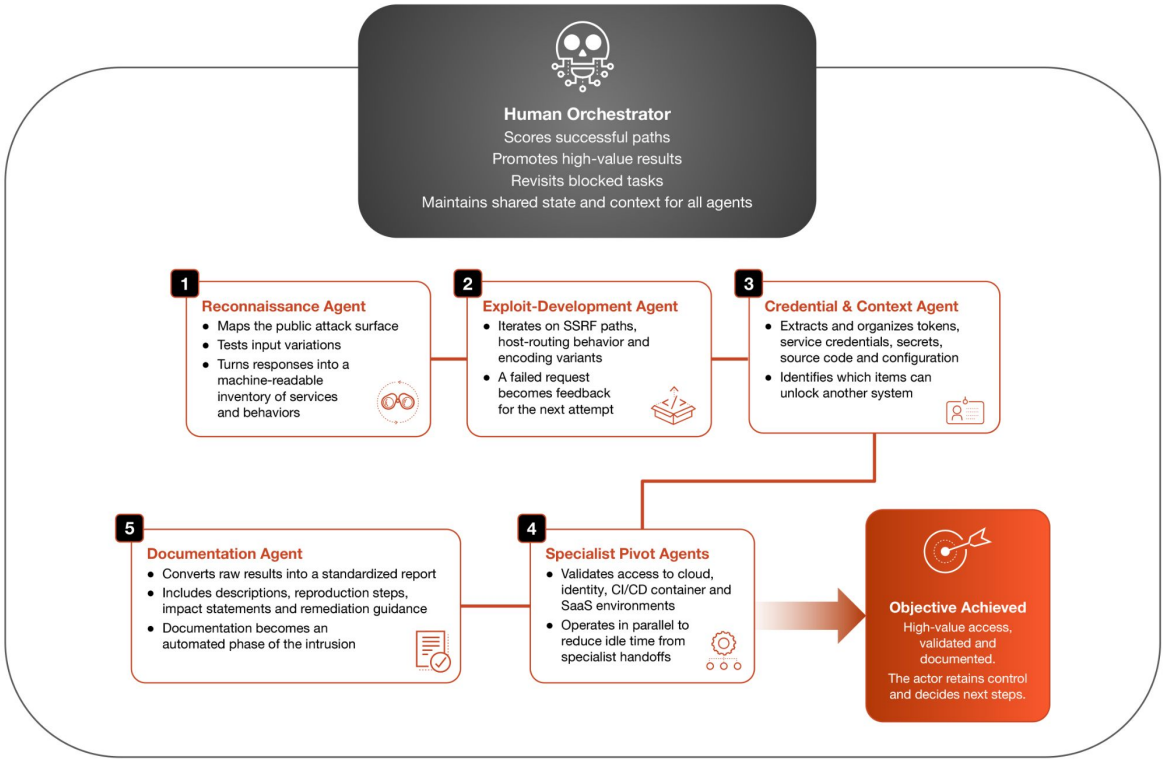
~2 WEEKS

Estimated human effort

<10 HOURS

Observed intrusion

PANW: An AI-Assisted Cyber Attack: Inside a Unit 42 Investigation



paloalto | UNIT 42

Offense gets a concrete success signal.

"Did this exploit work?"
!= "Is this system secure?"

An unreasonable assignment.

March → July
Build a team. Build a product.
Target: a full Chrome chain.

The output wasn't just one exploit.

Chrome findings.
Exim remote code execution.
Linux kernel vulnerabilities.

GOOGLE CHROME VULNERABILITY REWARDS PROGRAM

$250,000

Hello,

Chrome Vulnerability Rewards Program (VRP) Panel has decided to issue a reward of **$250000.00** for your report. Congratulations!

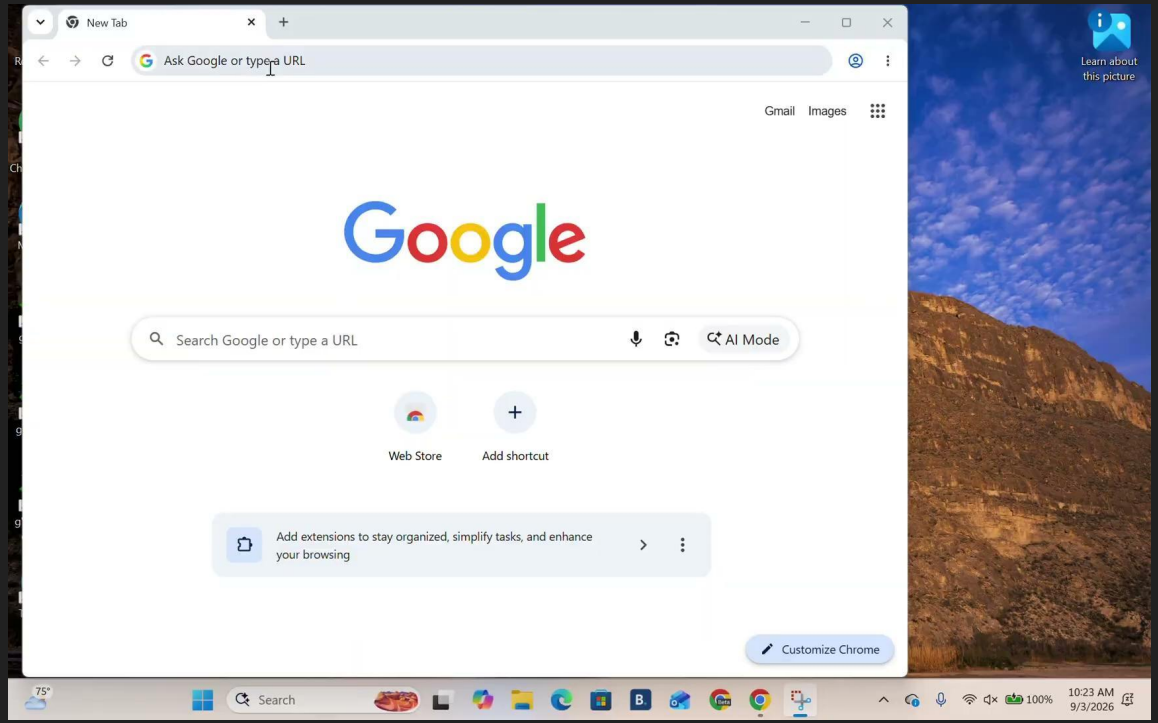
Rationale for this decision:

Full chain exploit. Well done!

PROOF, NOT POTENTIAL

POC || GTFO

Chrome.End to end.



Patching is not a strategy.

A patch needs a feedback loop.

26.0%

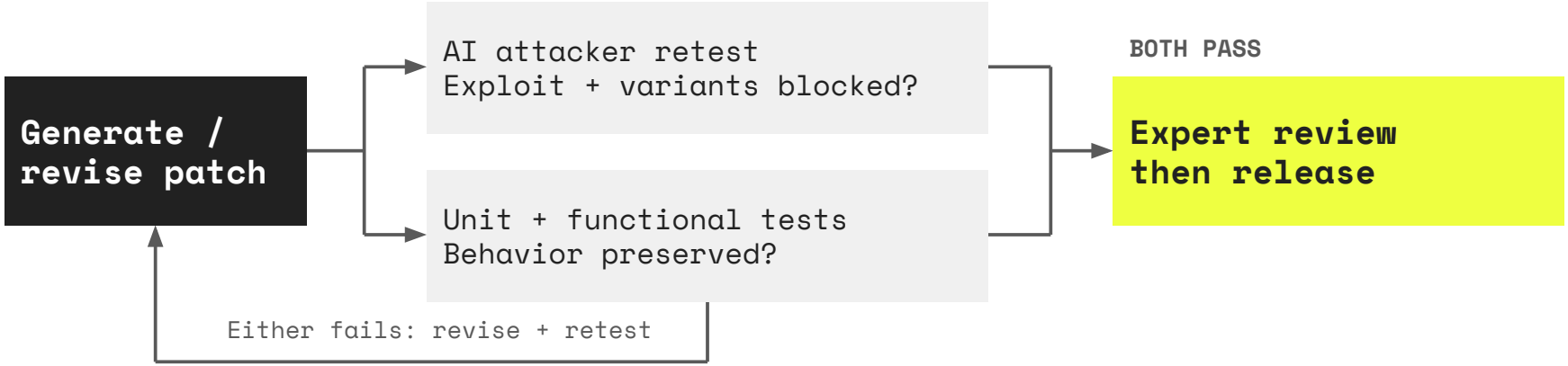
Fixed; behavior preserved

20.1%

Fixed; behavior changed

53.9%

Unresolved and/or new vulnerability



Source: 1Password, "Why AI-generated vulnerability patches still require expert human review"

Make the secure path the easiest path.

Guardrails, not gates.
Flow. Feedback. Less cognitive load.

Drive up the cost of offense.

Prevent: isolation + least privilege
Detect: canaries + behavioral signals
Contain: coordinated response

"Algorithms will be smarter than we are, and they will therefore be called upon to do what we cannot"

Dan Geer, 2015

Make attacking expensive again.

Make secure behavior cheap.
Make real risk visible.

NICO WAISMAN / XBOW